



File No.: EXP202403052

Sanctioning Procedure No.: PS/00165/2024

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A. (hereinafter, the claimant) filed a complaint with the Spanish Agency for Data Protection on February 4, 2024. The complaint is directed against INSTITUTO VALENCIANO DE SERVICIOS SOCIALES (IVASS) with NIF Q4601042G (hereinafter, the respondent/IVASS). The reasons for the complaint are as follows:

The claimant states the following: "At IVASS, fingerprints are taken for clocking in, and I submitted a request to have my fingerprint removed as it is a biometric data, and I preferred to sign in on paper with a pen. I presented the request to the on-duty manager and the center's management, and they denied it orally, with no written response."

Along with the notification, a photograph of a form titled "internal regime note" from IVASS, signed by the claimant, dated 13-12-23, is provided, in which the suppression of his fingerprint is requested and a change to a paper and pen clocking system or any other means of attendance control that does not involve the processing of biometric data.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), on February 23, 2024, this complaint was forwarded to the Vice-Presidency and Department of Equality and Inclusive Policies of the Generalitat Valenciana, to which IVASS is attached, according to the evidence obtained by the General Subdirectorate of Data Inspection, for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on 27/02/2024, as evidenced by the receipt in the file.

THIRD: On March 4, 2024, a first written response from the respondent, IVASS, was received by this Agency, in which it is stated, in summary, the following:

- IVASS does not have a system for monitoring the working hours of employees that stores biometric data, but rather a numerical code obtained from the fingerprint taken from the employee, which is not stored.

- Following the recommendations issued by a report from ***COMPANY.1, dated January 19, 2024, regarding the use of biometrics after the publication of the new Guide from the Spanish Agency for Data Protection on the processing of attendance control through biometric systems (attached as Document 1), the respondent contracted with ***COMPANY.2 (hereinafter, ***COMPANY.2) for the operation of the clocking control application, which allows the identification of IVASS staff through fingerprinting.

- According to the informational note from the ***PLATFORM.1 platform, which is attached as Document 2, provided to employees from the application, the following is stated:

“***COMPANY.2 terminals do not store an image of employees' fingerprints, only a multi-digit number generated from the fingerprint. It is completely impossible to create a photograph or retrieve an employee's fingerprint from that number. Practically, this means that each time you place your fingerprint on the reader, the reader generates a number. The program then compares whether this number corresponds to an employee or not – just as it would with a card. Please note that this number is not any confidential information, nor can it be used to obtain the fingerprint.”

- Therefore, the request made by the claimant on December 13, 2023, for the deletion of his fingerprint from the computer system used for clocking in cannot be accommodated.

The respondent did not attach documents 1 and 2 mentioned in its written response.

FOURTH: On March 21, 2024, IVASS submitted a new extension of the allegations presented on

March 4, 2024.

In this document, IVASS states that:

- Since 2010, IVASS has contracted with ***COMPANY.2 (now called ***COMPANY.3) for the operation of the clocking control application (**PLATFORM.1), which allows the identification of IVASS staff through fingerprinting.
- In light of this complaint, a report was requested from the Data Protection Delegation of the Generalitat Valenciana (hereinafter DPD of the GVA), which issued a first report on March 5, 2024, attached as Document 3.
- Following the submission of this report, several telephone conversations were held with the DPD, and ***COMPANY.2 was requested for the technical specifications of the **PLATFORM.1 program. Document 4, the commercial offer and presentation document of the mentioned application, is attached.
- On March 11, 2024, a new report from the DPD of the GVA was received, in which, after examining the same documents 1 to 4 that have been submitted in this procedure, the DPD states: "among other issues, it determines that

3/43

IVASS has incorrectly interpreted that the contracted system does not make use of biometric data, when the template obtained from a fingerprint is itself a biometric data. This observation is based on the fact that the fingerprint scanner captures unique patterns in each fingerprint, such as arches, loops, and whorls. These patterns are translated into a series of numbers and codes that form the biometric fingerprint template (number).

-

It states that IVASS initiated in December 2023 the bidding for a new software program that includes a comprehensive time tracking system for schedule control, in which the technical specifications do not include biometric processing.

-

It informs the Agency that: "In the coming months, the implementation of a new time control system is expected that will allow the entity to adapt to the recent guide from the AEPD and to the recommendations of the Data Protection Delegation of the Generalitat."

Along with its letter, it provides the following documentation:

-

It provides documents 1 and 2 that were mentioned in the previous letter dated March 4, 2023: Report from ***COMPANY.1 interpreting the Guide on biometric processing published in November 2023 regarding this Agency, and the informative note issued by the application designed by ***COMPANY.2, which is ***APPLICATION.1.

-

Document 3 is attached, which is a Report from the DPD of the GVA sent to IVASS on March 5, 2024, which briefly indicates the following:

- (i) It is noted that the processing of work schedule control through biometric systems is subject to the legal regime regarding data protection.
- (ii) It is brought to IVASS's attention that in January 2024 a query was sent to this Spanish Agency for Data Protection regarding certain application doubts about the new "Guide on presence control treatments through biometric systems approved by this Agency in November 2023." It states that the Guide is not mandatory, but they are awaiting a response to act accordingly.
- (iii) It requests that IVASS send certain documentation to the DPD of the GVA before March 25, 2024, which is mandatory in the case of implementing biometric fingerprint processing, including a prior risk analysis and the preparation of a Data Protection Impact Assessment (hereinafter, DPIA), in addition to verifying the facts subject to the complaint, and reviewing whether a lawful basis exists.

-

Document 4 is attached, which is an offer with commercial information about the ***APPLICATION.1 program, a time and personnel management platform that the respondent claims to have obtained from the entity with which it contracted the same, on March 21, 2024.

C/ Jorge Juan, 6

-

Document 5 is attached, which is the new report from the DPD of the GVA dated March 11, 2024, addressed to IVASS, where they acknowledge receipt of the response sent by IVASS to this Agency, and maintain:

(i) That the letter sent on March 4, 2024, by IVASS does not respond to all the questions posed by the Agency, and the documentation that the DPD indicated in its report of March 5, 2024, is still pending submission. Therefore, a new letter must be sent to this AEPD submitting a DPIA and proof of lawful basis, as this documentation is necessary to process the biometric fingerprint system contracted by IVASS.

(ii) Once the documents prepared by ***COMPANY.1 and ***COMPANY.2 provided by IVASS have been analyzed, the DPD indicates that: "It follows from the content of this report that the previous actions proposed by ***COMPANY.1 have not been carried out, nor have the measures mentioned in those recommendations been implemented. In this regard, it seems that IVASS has only considered the information provided by the company contracted to implement the fingerprint-based time tracking system, (...)"

(iii) In conclusion, and after analyzing Document 4 regarding the ***APPLICATION.1 platform that IVASS claims to have contracted for fingerprint time tracking, the DPD of the GVA informs IVASS of the following, that it has only presented an offer from 2021, and that it is necessary to provide the updated technical specifications from ***COMPANY.2. However, based on the offer presented as Document 4, the DPD of the GVA concludes the following:

"3.- The offer submitted by the awarded company does not provide information or assessment regarding the use or non-use of biometric data by its time tracking control system, so IVASS only has the aforementioned informative note, from which it has been incorrectly interpreted that the system does not make use of biometric data, since the terms in which it has been drafted are directed for the affected individuals to consider it as such. However, it has already been documented in the previous section that this is not the case, as the template obtained from a fingerprint is a biometric data.

4.- Therefore, it is the recommendation of this delegation that IVASS should again address the request from the AEPD, taking into account both the guidelines from the first report sent to them on March 5 by this delegation, as well as the content of section 2 of this report and other observations."

FIFTH: On March 27, 2024, in accordance with Article 65 of the LOPDGDD, the complaint submitted by the complainant was admitted for processing.

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es

SIXTH: On June 4, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the accused party, for the alleged infringement of Article 38 of the GDPR, Article 9 of the GDPR, and Article 35 of the GDPR, classified under Article 83.4.a) of the GDPR and Article 83.5.a) of the GDPR.

SEVENTH: On June 18, 2024, the accused party submitted a written statement of allegations regarding the initiation of sanctioning proceedings, distributed in 7 points or arguments, in which, in summary, IVASS states the following:

- First Point. On the legal nature of IVASS. It confirms the legal nature of IVASS as stated in the initiation agreement and acknowledges its role as the data controller of its employees' personal data.
- Second Point. Contracting of the timekeeping system in 2010, and therefore, prior to the Guide on the processing of attendance control through biometric systems from November 2023. The adaptation of IVASS to the new guidelines established by the AEPD could not be carried out immediately in a public

law entity that follows public procurement regulations and manages a large volume of personnel.

- Third Point. Tendering of the timekeeping control service contract. As previously informed to this AEPD, "the Procurement and General Affairs Area of IVASS was processing the tender for the timekeeping control service, in which the technical specifications will take into account the observations made by the Data Protection Delegation of the Generalitat."

However, once consulted with the Procurement and General Affairs Area of the entity, it is reported that the tender for ***REFERENCE.1, processed under the establishment of the dynamic acquisition system of the Generalitat's central purchasing body, ***REFERENCE.2, for the contracting of the supply under a rental regime of a software package in SAAS mode, which includes an integrated timekeeping system for time control, work shift planning, and maintenance for IVASS centers and services, has been declared void due to the lack of competing companies.

It should be noted that the Technical Specifications of this contract had already included as a requirement the supply and implementation of an estimated number of timekeeping terminals through a non-biometric system that complies with applicable data protection regulations, including any necessary additional materials, such as cards or other supports, if applicable, and access to the employee portal (provided as DOCUMENT NO. 1).

- Fourth Point. Use of the timekeeping system ***APPLICATION.2. Since May 2, 2024, the employees of the entity's bureaucratic services have been using the application ***APPLICATION.2, which is controlled through ***APPLICATION.3, the corporate user authenticator of the GVA. This system allows for the use of different methods to authenticate the user: 1. Access via GENERALITAT Domain. 2. Access via GVA Email. 3. Access

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/43

by means of the Digital Certificate.

4. Access via Justice Domain. The user manual for ***APPLICATION.2 of the Generalitat Valenciana is attached as DOCUMENT NO. 2.

IVASS indicates that the extension of this tool to all workers in the socio-health centers managed by IVASS has been evaluated; however, it has not been possible, on one hand, because a large part of these professionals provide direct care in the various centers and services that can be grouped into a network of Residences for the care of individuals with functional and intellectual disabilities; day care centers, to provide reception, health, and personal hygiene services; a network of supervised housing for the care of individuals with functional and intellectual disabilities; occupational centers, for the coordination of reception, educational, labor, and personal occupational activities; guardianship services for individuals with judicial support measures; administrative and bureaucratic services for the management of centers and services.

In ***APPLICATION.2, the registration of personnel is carried out through the guide of departments and personnel structure PROP of GVA, so the rotation of personnel and daily replacement of about 1500 professionals would not guarantee the activation and registration of personnel for daily logging. Furthermore, this personnel does not have their own computer that allows for clocking in through ***APPLICATION.2 and, on the other hand, this tool does not adapt to the needs required by the direct care service in our centers, among other reasons, because it does not reflect the different rotating work shifts, group planning, incidents and shift changes, the number of professionals on the shift, etc. In short, IVASS states that ***APPLICATION.2 is a system intended for clocking in via computer for those public employees who work in administrative services, with the schedules established there by the DGTIC, among other relevant issues mentioned previously, which is why it has been possible to implement it (with some limitations) in the central offices of this entity, but it cannot be implemented in IVASS services as it is currently configured, without the necessary adaptation to the different structure and schedules of IVASS personnel.

-

Fifth Point. Regarding the measure of preparing and overcoming a DPIA, with the participation of the

DPO, that enables the use of a biometric clocking system, the General Directorate of IVASS has opted for the elimination of clocking control through any biometric identification system for IVASS personnel. Consequently, in principle, the preparation of a DPIA report would not be necessary.

-

Sixth Point. On compliance with the corrective measure of participation of the Data Protection Delegation of the Generalitat Valenciana in matters related to data protection raised in IVASS.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/43

It is hereby informed that we are in communication with the DPD of the Generalitat Valenciana for its participation in data protection issues that may arise in this entity.

As proof of this, the Agreement to Initiate Sanctioning Procedure was forwarded to the DPD for its knowledge and, where appropriate, for its advice to this entity. Following this procedure, there have been exchanges of emails and telephone calls.

On the other hand, the DPD of the Generalitat Valenciana sent a letter in April of this year to the Administration of the Generalitat and to the entities of its Instrumental Public Sector informing about some issues, among them: the specific function of the DPD to act as a contact point with the control authority (the AEPD); the way to address the requirements of the AEPD, etc. (this is recorded as DOCUMENT NUMBER 3).

-

Seventh Point. Compliance with the provisional measure agreed by the AEPD regarding the provisional suspension of processing.

IVASS has proceeded to change the system of clocking in and the definitive suspension of all processing of personal data through a clocking system by reader that the terminals of the current application have.

In this way, on June 6, 2024, an informative note was sent to the entire staff of the entity to announce the change of the clocking system. Thus, instead of using the terminal reader (which has been disabled), clocking in would be done generally, through an employee code and password entered into the terminal, until the tender for the new application.

EIGHTH: On November 14, 2024, a proposal for resolution was formulated, in which the allegations to the initiation agreement were dismissed, and the following was proposed:

“That the Director of the Spanish Agency for Data Protection declare that the INSTITUTO VALENCIANO DE SERVICIOS SOCIALES (IVASS), with NIF Q4601042G, has infringed the provisions of Article 38 of the GDPR, Article 9 of the GDPR, and Article 35 of the GDPR, administrative infringements classified in Article 83.4.a) of the GDPR and Article 83.5.a) of the GDPR.

That the Director of the Spanish Agency for Data Protection order the INSTITUTO VALENCIANO DE SERVICIOS SOCIALES (IVASS), with NIF Q4601042G, to, pursuant to Article 58.2.d) of the GDPR, within 7 months, prove that it has complied with the measures indicated in the Legal Basis XII of this Proposal for Resolution;

That the provisional measure of suspension of the processing of biometric data agreed upon in the Initiation Agreement be maintained and elevated to definitive status, which must be evidenced by the INSTITUTO VALENCIANO DE SERVICIOS SOCIALES (IVASS), with NIF Q4601042G, in the terms referred to in the Legal Basis XIII of this Proposal, and within 10 business days from the notification thereof. This measure shall remain in effect until its final resolution, in which it must be confirmed, modified, or lifted, without prejudice to what is stated in the document.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/43

provided for in Article 56.5 of the LPACAP, and it may be agreed in the final resolution to impose a

definitive limitation or prohibition on such processing operations in accordance with the provisions of Articles 58 of the GDPR and 69 of the LOPDGD.

NINTH: On November 29, 2024, a written statement of allegations regarding the proposed resolution distributed in five points was received, which, in summary, states the following:

-

First. Regarding the tender for the service contract for timekeeping control.

On the one hand, the IVASS reiterates the same arguments that were indicated in the initiation agreement, noting that by means of a letter dated 03/21/2024 submitted during the preliminary phase prior to the initiation of this sanctioning procedure, this Agency was informed of the processing of the tender for the timekeeping control service, in which the technical specifications would take into account the observations made by the Data Protection Delegation of the Generalitat, in which it was intended to contract the supply and implementation of an estimated number of timekeeping terminals through a non-biometric system that complies with applicable data protection regulations, including any necessary additional materials, such as cards or other supports, if applicable, and access to the employee portal.

And, it also repeats that, after submitting said letter of 03/21/2024, the IVASS consulted the Area of Contracts and General Affairs of the entity and was informed that the tender for ***REFERENCE.1, processed under the establishment of the dynamic acquisition system of the Generalitat's central purchasing, ***REFERENCE.2, for the contracting of the supply under a rental regime of a software package in SAAS mode, which includes a comprehensive timekeeping system for time control, work shift planning, and maintenance for the centers and services of IVASS, had been declared void due to the lack of competing companies.

As a new development, the IVASS informs in this letter of the following: "Currently, the preparation of a technical specifications document for the contracting of a software package that includes a comprehensive human resources management system for the various centers and services of IVASS is being finalized. With this, a non-biometric timekeeping system will be implemented without prejudice to the provisional solution adopted and specified in the following section."

-

Second.- Use of the timekeeping system

***APPLICATION.2.

The information that was already provided in Point Four of the written allegations to the initiation agreement regarding the application ***APPLICATION.2, which has been used since May 2, 2024, for the staff of the bureaucratic services of the entity, is also reiterated, along with the reasons why it cannot be used for the recording of working hours of the socio-health centers managed by the IVASS. It is noted that, for this reason, a provisional solution has been opted for the recording of working hours of the workers in the socio-health resource network who currently employ an identification system of C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/43

user-password through the introduction of a numeric code at the timekeeping terminals. It is emphasized that this will be replaced by the new system resulting from the tender for the new technical specifications referred to in the previous section.

-

Third.- On the corrective measure of preparing and overcoming a Data Protection Impact Assessment (EIPD).

It is reiterated that, regarding the measure of preparing and overcoming an EIPD, with the participation of the DPD, which enables the use of a biometric timekeeping system, the General Directorate of IVASS has directly opted for the replacement of the previous model of attendance control through fingerprint scanning with a user-password numeric code timekeeping system at the various centers and resources of the network and by using the application ***APPLICATION.2 for personnel assigned to bureaucratic services.

-
Fourth.- Compliance with the corrective measure of participation of the Data Protection Delegation of the Generalitat Valenciana in matters related to data protection raised in IVASS.

Again, it is pointed out that IVASS is in communication with the DPD of the Generalitat Valenciana for its participation in data protection issues that may arise in this entity, and that it sent a letter in April of this year to the Administration of the Generalitat and to the entities of its Instrumental Public Sector informing of some issues, which was submitted along with the allegations of the initiation agreement.

As new developments regarding the allegations of the initiation agreement, it is added that:

(i) more recently, on November 18, the proposal for resolution of the present procedure was communicated to the DPD of the Generalitat Valenciana; and (ii) a technical figure has been established in IVASS for communication with the DPD of the Generalitat Valenciana regarding data protection matters.

-
Fifth.- Compliance with the suspension measure agreed upon by the AEPD within the framework of the sanctioning procedure.

As indicated in the allegations to the initiation agreement, on June 6, 2024, an informative note was sent by email to the entire staff of the entity to announce the change of the provisional timekeeping system based on entering an employee's numeric code at the terminal, which is attached as DOCUMENT NO. 1).

In addition to this, for the first time in the procedure, the email dated 06/06/2024 is provided, in which the replacement of the fingerprint timekeeping system with a provisional manual timekeeping system at the terminal referred to in the allegations to the initiation agreement is communicated. This was sent by B.B.B., from (...), with the subject "CHANGE INSTRUCTIONS TIMEKEEPING PERSONNEL URGENT" and the recipients General/All employees (without restrictions) and two attached documents titled "NOTE TIMEKEEPING TERMINAL CHANGE05062024" and "PAPER TIMEKEEPING MODEL". TENTH: On 04/12/2024, a written submission from the responding party was received, which attached the same documents referred to in the previous point.

From the actions taken in the present procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: IVASS acknowledges in its writings of March 4, 2024, March 21, 2024, and June 18, 2024, that in 2010 it contracted with the entity ***COMPANY.2 (now called ***COMPANY.3) the so-called ***PLATFORM.1 and that it was implemented mandatorily for the purpose of recording the working hours of its public employees through fingerprint detection terminals.

In its writing of June 18, 2024, it attaches the email that was sent on June 6, 2024, to the entire staff of the entity to announce the change of the timekeeping system. It expressly states that: "Thus, instead of using the terminal reader (which has been disabled), timekeeping would generally be done through an employee code and password entered at the terminal, until the tender for the new application, providing with its allegations to the Proposal for Resolution the content of this email which is attached as DOCUMENT 1, whose body and attached informative note state the following:

In the text of the email dated 06/06/2024, the following was indicated:

"Hello,

Following the indications of the Subdirectorate and in order to comply with the executive instruction of the Data Protection Agency, THE FINGERPRINT TIMEKEEPING SYSTEM WILL BE REPLACED BY CODE TIMEKEEPING AT THE TERMINAL/MANUAL TIMEKEEPING, urgently (centers with the current application ***PLATFORM.1)

This change entails the disabling of the readers at the terminals and the assignment of a code to each employee so that they can clock in with their code and pin.

We attach an informative note for the employees and bulletin board,

Each shift manager/manager of ***PLATFORM.1 must review THE IDs (CODE OF EACH EMPLOYEE AND PASSWORD TO PROVIDE TO THE STAFF), likewise, the timekeeping mode in

***PLATFORM.1 must be changed to code and assign a password in the application so that it can be clocked in (it would be the same number as the code)

ACCESS TO GLOBAL-USERS:

AUTHORIZATIONS: CONFIGURE IDENTIFICATION MEANS (...) AND FROM THERE THE CODE IS OBTAINED (...)

They will have to uncheck the fingerprint (to deactivate this timekeeping method) and check the option for password. The password must be entered as

11/43

same code

that appears as id: From this moment on, staff will be able to clock in. (...)

Therefore, the fingerprint must be deactivated and activated via password, and the employee code must be entered in the password space (...).

From today, it will be necessary for staff to have their code and password to be able to clock in.

In any case, manual time sheets must be provided, in case there are staff without a code or for centers without a terminal.

Starting tomorrow, C.C.C. will be responsible for coordinating the deactivation of clock-in readers (covering them so that they cannot place their finger on the reader).

For the moment, and until the new attendance registration method is tendered, we have no other options (code clocking or manual on paper). (...)

On the other hand, the attached informative note contains the following content:

“CHANGE IN CLOCKING SYSTEM AT IVASS CENTERS

In order to comply with the executive directive of the Data Protection Agency and labor regulations, starting June 10, 2024, the general clocking method will be modified.

Clocking with the reader at the terminals (that screen will be disabled) will be replaced by clocking through the assigned code and password.

In order to record the workday, without using the “READER,” staff must clock in at the terminals using the “CODE” employee ID and a password.

For each employee to access the code, they must go to their center manager to be informed of the corresponding number and password.

Thus, clocking will be carried out normally through the terminal (this is a personal and non-transferable pin code of the employee) (...)

To respect the privacy of clocking with a code, it is informed that staff must maintain at least one meter of distance from the colleague who is clocking in.

Staff who do not have an employee code from ***PLATFORM.1, or in centers where there is no terminal available, must clock in on paper, for the purposes of recording the workday and compliance with regulations, until a new attendance registration application is implemented.”

SECOND: According to the report from the DPD of the GVA dated March 11, 2024, after analyzing the documentation submitted by IVASS, it is determined that ***PLATFORM.1 processes biometric data, as it generates and stores a biometric template based on the employees' fingerprints and compares the employee's fingerprint at the time of registration with the stored template in order to carry out the corresponding unique identification of the same.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/43

In its response to the transfer dated March 21, 2024, IVASS considers that its system does not process biometric data, and therefore it was not necessary to comply with the requirements applicable to this type of processing. It expressly states that it has reached this conclusion based on what is indicated in the informative note from ***PLATAFORMA.1 provided as Document 2. This note, addressed to the users of the program whose fingerprint is collected, states the following:

“The terminals of ***EMPRESA.2 do not store an image of the employees' fingerprint, only a multi-digit number that is generated from the fingerprint. It is completely impossible to create a photograph or retrieve an employee's fingerprint from that number. Practically speaking, this means that every time

you place your fingerprint on the reader, the reader generates a number. The program then compares whether this number corresponds to an employee or not – in the same way it would with a card. Please note that this number is not any confidential information, nor can it be used to obtain the fingerprint.”

THIRD: It is established that as of the date of entry into force of the GDPR (May 25, 2018), IVASS continued to process biometric data (fingerprint) of its employees using the aforementioned ***PLATAFORMA.1 until June 10, 2024, as stated in the informative note sent on June 6, 2024, to the employees according to the first proven fact, without having conducted and passed the corresponding DPIA referred to in Article 35 of the GDPR, nor having demonstrated the existence of any of the exceptions in Article 9.2 of the GDPR that would enable it to carry out such processing for the control of its personnel's working hours, without which such processing is prohibited.

This fact is considered established since – in addition to the claimant acknowledging that it did not consider it necessary to comply with these requirements because it believed it was not processing biometric data until it consulted its DPO in the context of this procedure – it has not provided such DPIA or evidence of the existence of an exception in this procedure or to its own DPO, despite having been requested to do so on several occasions by both agencies.

FOURTH: It is recorded in the file that the DPO of the Generalitat Valenciana, which is the autonomous administration to which IVASS is attached, was not consulted by IVASS regarding the aforementioned employee timekeeping system it has been using since 2010 to verify whether the processing it was carrying out to record its employees' working hours through fingerprint detection complied with the provisions of the new GDPR.

That is, there is no record of the DPO's participation, nor of IVASS's prior consultation with it when the new GDPR came into effect, nor subsequently when the report from ***EMPRESA.1 dated January 19, 2024, was received. Furthermore, there is also no record that IVASS consulted the DPO before responding to the request made by the claimant on December 13, 2023, in which he requested the deletion of his fingerprint and a change to a paper and pen timekeeping system or any other means of attendance control that does not involve the processing of biometric data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/43

In view of the documentation submitted to the procedure, it is deduced that the DPD of the GVA was not consulted regarding the biometric system implemented by IVASS until February of this year 2024, by the respondent following the request made by this Agency in connection with the present procedure, issuing then two reports on March 5 and 11, 2024, where it examined the implemented system, determining that it is a biometric processing, that the respondent had misinterpreted the documentation obtained from the data processor who developed the ***PLATAFORMA.1 program, and that it was necessary to comply with the obligation to carry out and surpass a prior EIPD, as well as to demonstrate the existence of a lawful basis, exception, and the rest of the principles and obligations provided for in data protection regulations.

FIFTH: The entity responsible for the processing of biometric data carried out through the implementation of the ***PLATAFORMA.1 Program for the registration and control of employees' working hours referred to in this procedure is IVASS, since it has its own legal personality independent of the Generalitat Valenciana, despite being organically attached to it, as it acknowledges in its written allegations to the initiation agreement.

LEGAL GROUNDS

I

Competence and procedure

In accordance with the powers granted by Article 58.2 of the GDPR and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the Guarantee of Digital Rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish

Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary issues regarding the processing of biometric data

2.1. Definition and characteristics of biometric data.

The GDPR defines in Article 4.14 biometric data as "personal data obtained through a specific technical processing, related to the physical, physiological or behavioral characteristics of a natural person which allow or confirm the unique identification of that person, such as facial images or fingerprint data."

Any biometric system for controlling working hours must first register the identity of the user in the system by capturing a series of biometric parameters. The aim is to process those parameters to identify the person each time they enter and exit through the access point. Processing that starts from an image of the fingerprint, which is converted into what is called a biometric template or fingerprint vector, which is stored in the system.

Biometric data processing systems are based on collecting and processing personal data related to the physical, physiological, or behavioral characteristics of natural persons, among which the neural characteristics of these may be included, through devices or sensors, creating biometric templates (also referred to as signatures or patterns) that enable the identification, tracking, or profiling of such individuals.

As the report of the DPD of the GVA dated March 11, 2024, submitted to this procedure rightly points out, the respondent starts from a misinterpretation of the content of the informative note of the application used for clocking in, since the fact that biometric systems are translated into a numerical code does not imply that biometric data is not being stored or processed.

The processing of data carried out through biometric systems was explained in Convention 108+ for the protection of individuals with regard to the automated processing of personal data approved by the Council of Europe, which since January 1981 has stated in its paragraph 60 the following, as noted in the Guide on presence control treatments using biometric systems published in November 2023:

"A biometric data contained in a system is stored in the form of a biometric template or pattern. A biometric template is a representation of a human biometric characteristic, such as a face or a fingerprint, in such a way that it can be efficiently and effectively interpreted by a machine for a specific purpose or purposes. The biometric template is not intended to be interpreted by a person, like a photograph, but is intended to be processed in an automated process, that is, to be efficiently and effectively interpretable by a machine. This form of storage would allow for the singularization of an individual and the execution of actions automatically, profiling or inferring information about a subject such as attitudes or behavior patterns, etc.

In the case of identification or authentication operations, for a biometric template to be effective, it is necessary that the templates generated from two distinct individuals are clearly distinguishable. In that case, the template acts as a unique identifier of the person. The fact that, from a biometric template, for example, of facial recognition, it does not...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/43

The ability to reconstruct the original face is irrelevant, as it is a unique identifier that singularly identifies the individual, at least within the framework of automated processing. Similarly, from just the DNI number, one cannot reconstruct a name or a face. Both unique identifiers, biometric template or DNI number, can be associated with personal data and additional attributes in a file. Unlike a DNI number, the biometric template is not assigned to a person; rather, it is generated directly from the observation of unique and unalterable physical characteristics of the individual, without the need to resort to documents, other devices, or third-party databases.

Well then, the decision to implement a method of monitoring employees' working hours that involves the processing of biometric data, such as those based on fingerprint detection, as is the case here (or facial recognition in other instances), is not a trivial decision. Such types of processing are based on technology that can be truly intrusive and require a calm ethical and legal debate before deciding on their implementation, given that collecting the fingerprint of personnel can have very adverse effects on the fundamental values and human integrity of these employees that do not occur with other attendance control methods. Consider just some of their special characteristics and think about the significant impact they produce when these biometric data are compromised, compared to other methods (signature and completion of sheets, or clocking in with magnetic cards):

- Each individual has unique fingerprints that show specific characteristics that can be measured to determine if a fingerprint matches a registered sample. Therefore, they are unique, permanent, or definitive over time, and the person cannot free themselves from them; they can never be changed, not even with age, so the damage caused in the event of compromise, loss, or intrusion into the system is irreparable in this case. Unlike a password, in the event of loss, the data of our fingerprint or face cannot be changed.
- Furthermore, because biometric data are inherent to a person and perpetual, the user can use the same data across different systems, which poses an additional risk.
- While traditional authentication methods such as passwords require a 100% character-by-character match to allow the user to access, for example, an account or application (deterministic methods), biometric methods are referred to as "probabilistic," because they are based on the probability that the user attempting to access a particular device or application is the same person as the registered user. We can measure the performance of a biometric system based on three main characteristics. These are: false rejection rate (FRR), false acceptance rate (FAR), and equal error rate (ERR). The false rejection rate represents the probability of detection errors by a biometric system, meaning that it cannot recognize a user whose biometric characteristics are already in the database. In the event of a rejection, the person must verify their identity again. From a security and protection perspective, this rate does not necessarily mean that it is a negative outcome. Each biometric method, whether facial reading, fingerprint, palm print, iris, etc., has different values for different rates based on which a system rejects or accepts entries.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
16/43

2.2. Biometric templates as special category personal data and high risk.

According to the definition provided by Article 4.14 of the GDPR, biometric data processed by these systems is considered personal data as long as the purpose of the processing is the identification or authentication of a person, as defined in Article 4.1 of the GDPR, which defines personal data as: "1. Personal data: any information relating to an identified or identifiable natural person ('the data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more specific elements of the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person."

It should be noted that the approval of the GDPR has brought about a paradigm shift in the field of personal data protection aimed at further ensuring citizens' control over their personal data, establishing high protection standards adapted to the digital environment in which we live. In accordance with the Principle of Proactive Responsibility, which inspires the new regulation, the new GDPR emphasizes that the data controller must seriously assess the risks of the processing they wish to establish concerning the rights and freedoms of the data subjects (always prior to initiating any processing, and continuously if they decide to proceed), opting for a risk analysis approach by design and by default, in order to identify them, determine the likelihood of their occurrence and their impact,

and foresee measures and guarantees that eliminate or, at least, mitigate the identified risks, preventing their occurrence. Likewise, certain obligations must be fulfilled, and specific principles established by the regulation must be respected.

Thus, whenever personal data of any kind is processed, the data controller must comply with the principles and obligations set forth in the data protection regulation for all types of personal data. However, when the personal data to be processed is biometric (fingerprints, facial recognition, etc.), it must also be considered that—unlike what was the case under the regime prior to the GDPR—this type of data is classified as special category personal data under Article 9, the processing of which is prohibited, unless one of the exceptions provided for in Article 9.2 of the GDPR applies. This does not exempt the necessity of having a lawful basis as provided in Article 6 of the same, among many other requirements and principles that must be complied with by anyone who decides to opt for this type of processing.

According to Article 9.1 of the GDPR, the processing of biometric data is prohibited when it is: “biometric data processed for the purpose of uniquely identifying a natural person.” While Recital 51 of the GDPR includes both identification and authentication procedures: “since they are only included in the definition of biometric data when the fact that they are processed by specific technical means allows for the unique identification or authentication of a natural person. Such personal data must not be...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
17/43

treaties, unless their processing is permitted in specific situations contemplated in this Regulation.” In this regard, it is important to emphasize that the qualification as special category data necessarily implies the observance of special caution when determining whether it is possible to carry out processing of such data.

Among other things, and in addition to the existence of an exception that allows for the lifting of the prohibition in Article 9.1 of the GDPR, that there is a lawful basis under Article 6 of the GDPR, and that the principles of the GDPR are met, the entity intending to implement biometric data systems (in this case, IVASS) should have previously analyzed the concurrence of the necessary criteria of necessity, suitability, and proportionality of the processing.

That is, anyone intending to establish processing of personal data of this nature must, first and foremost, ensure that they surpass what has been termed in jurisprudence as “the triple test of proportionality,” particularly considering whether the processing of biometric data is suitable, proportional, and above all, necessary. If there are other non-biometric systems that allow achieving the same purpose of effectively identifying-verifying the identity of individuals, it will not be necessary to initiate biometric processing, and therefore, the implementation of this system will be considered contrary to the GDPR. This assessment must be the starting point of their analysis, as only if these methods surpass the aforementioned triple test will compliance with other requirements or guarantees be required.

Moreover, in addition to being special category data, the processing of biometric data is considered high risk according to the provisions of paragraph 4 of Article 35, which states that “The supervisory authority shall establish and publish a list of the types of processing operations that require an impact assessment regarding data protection in accordance with paragraph 1,” given that it is included among the processing types listed that require an impact assessment regarding data protection, as made public by the AEPD in development of the provision contemplated in the fourth paragraph of the aforementioned Article 35.

There is no doubt about the high-risk nature of this data, considering that biometric data meets the criteria corresponding to numbers 4, 5, and 10 of that document (those involving the use of special categories of data; the use of biometric data; and those involving the use of new technologies or an innovative use of established technologies). Therefore, the processing of biometric data can never be initiated without having developed and surpassed a valid DPIA prior to the processing.

Thus, since the entry into force of the GDPR, when processing is of “high risk,” as is the case with biometric time-tracking methods, it is mandatory to always conduct an impact assessment (DPIA), in accordance with the provisions of Article 35.1 of the GDPR, and this DPIA must be prior to the commencement of processing, but must also be conducted continuously. It will not be sufficient to merely conduct it; it must be considered valid because it meets the requirements set forth in the aforementioned article, particularly that it contains at least the information specified in Article 35.7 of the GDPR.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
18/43

2.3. IVASS as the data processing operations manager for biometric data of public employees using the fingerprint timekeeping system.

Article 4.2 of the GDPR defines “processing of personal data” as:

“any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination or any other form of enabling access, comparison or interconnection, restriction, erasure or destruction.”

If the processing consists of the daily recording of working hours through fingerprint recognition, it will necessarily require a varied set of operations by the controller that involve the processing of biometric personal data according to Article 4.2 of the GDPR. These may include: the collection or capture of the employee's fingerprint, its processing to convert it into a biometric vector or template, its registration, storage, the identification-authentication of the employee in the timekeeping process, the recording of time and other possible data, its processing to determine excess or missing hours, its conservation, erasure, restriction, etc. All of these will be operations of processing biometric personal data (biometric template) of a special category and high risk.

In this case, the entity being claimed has submitted several writings in which it changes its argument regarding the nature of the personal data processed through the fingerprint detection system implemented at IVASS:

While in an initial writing dated March 4, 2024, the respondent initially maintained that: “At IVASS, there is no system for controlling the working hours of employees that stores biometric data, but rather a numerical code obtained from the fingerprint taken from the employee, which is not stored,” indicating that its system complies with the recommendations of the report from ***COMPANY.1 dated January 19, 2024, regarding the interpretation of the Guide published by this Agency in November 2023, contracting with ***COMPANY.2 for a program called “***PLATFORM.1.” It considers that timekeeping through fingerprint recognition does not involve the processing of biometric personal data, since, according to the information note appearing in the aforementioned program, the program does not store the fingerprint but rather a numerical code.

However, in its second writing dated March 21, 2024, and following the recommendations made by the DPD of the GVA in its Reports of March 5 and March 11, 2024, the respondent changes its argument and acknowledges that the program ***PLATFORM.1 used for timekeeping of working hours through fingerprint recognition by employees of IVASS does involve the processing of biometric data, as it stores and uses a biometric template to perform the unique identification of employees, expressing its intention to replace this system with another that does not use biometric methods.

In its submission of allegations to the initiation agreement, it claims that it has eliminated this system and has sought alternatives for timekeeping that do not involve the processing of biometric data, informing this Agency of the results of the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
19/43

failed attempts to change the current system for another that complies with the provisions of personal data protection regulations.

From the documentation provided, it is clear that, as noted by the DPD of the GVA in the two reports submitted to this procedure, there is no doubt that the program implemented by IVASS processes biometric personal data, since the purpose of the implemented system is to determine the identity of the employee who enters or exits the workplace and to verify the time and date of the beginning and end of their workday. Given that the process assigns an identifier (the biometric template obtained by collecting the fingerprint samples of the interested parties) that allows for the identification of an individual and distinguishes them from others through "elements specific to physical, physiological, genetic, or psychological identity."

Therefore, this implies that the entity being claimed has been processing biometric data since 2010, continuing the processing after the entry into force of the GDPR until June 10, 2024 - it has been evidenced in the allegations to the proposal that IVASS proceeded to replace it with another provisional timekeeping system that did not use biometric methods on that date - thus, it would be responsible for complying with the obligations established by data protection regulations for processing biometric personal data, in accordance with the provisions of Article 4.7 of the GDPR, which defines the data controller as:

"(...) The natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; if the law of the Union or of the Member States determines the purposes and means of the processing, the data controller or the specific criteria for their appointment may be established by the law of the Union or of the Member States."

This implies that the entity being claimed is the presumed responsible party to which this sanctioning procedure must be directed in the event of committing any of the breaches classified as infringements under the GDPR, in accordance with the provisions of Article 70.1 a) of Organic Law 3/2018, of December 5, on personal data protection and the guarantee of digital rights (hereinafter, LOPPD):

"Article 70. Responsible parties.

1.

Those subject to the sanctioning regime established in Regulation (EU) 2016/679 and in this organic law are: a) The data controllers. b) The data processors. c) The representatives of data controllers or processors not established in the territory of the European Union. d) Certification entities. e) Accredited entities supervising codes of conduct. (...)"

III

Response to the allegations regarding the initiation agreement

The initiation agreement of this file charged the entity being claimed with the commission of 3 alleged administrative infringements of Article 35 of the GDPR, for not having a prior impact assessment that meets the minimum requirements of that provision; one infringement of Article 9 of the GDPR for not demonstrating the existence of an exception that lifts the prohibition on processing biometric data, and one

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/43

Violation of Article 38 of the GDPR, for failing to consult its DPO regarding whether the processing of recording and controlling the working hours of its staff, which was being carried out through a fingerprint system, complied with the provisions of the new GDPR.

In response to this allegation, IVASS submitted arguments on June 18, 2024, in which it did not expressly address the main subject of this procedure, as it made no reference to the prior existence of a DPIA, the concurrence of an exception under Article 9, or prior consultation with the DPO as of the date of the entry into force of the GDPR (May 25, 2018), the date on which such obligations began to be enforceable, requiring the relevant adaptation of the system used since 2010 in the event that it was decided to continue processing biometric data after the entry into force of the GDPR.

The arguments against the initiation agreement made by IVASS did not provide any argument or

document justifying compliance with these requirements during the period from the entry into force of the GDPR to the present, but merely pointed out: (i) the reasons why the system for recording the working hours of its staff, implemented in 2010, has not yet been adapted to the new provisions of the GDPR; (ii) and the corrective measures adopted, informing that the fingerprint recording system has been eliminated, in compliance with the provisions of the initiation agreement of this procedure, replacing the timekeeping system of its staff with one that requires entering a username and password, which, on the other hand, is not substantiated.

Thus, on one hand, the reasons were indicated for why the relevant adaptation to the provisions of the GDPR could not be carried out previously:

- On one hand, IVASS states that the application installed with ***COMPANY.2 was implemented in 2010, before the entry into force of the GDPR, and that its adaptation to the same has not been possible until now because a tender for a new system that does not use biometric data was planned, but information has been requested from the contracting area of IVASS, and it has indicated that such tender has been declared void. Document 1 is attached, which is the Technical Specifications Document, processed under number ***REFERENCE.1, under the establishment of the dynamic acquisition system of the purchasing center of the Generalitat, ***REFERENCE.2, for the contracting of the supply under a rental regime of a software package in SAAS mode, which includes an integrated timekeeping system for time control, work shift planning, and maintenance for the centers and services of IVASS, which has been declared void due to the lack of participating companies.

- Furthermore, the complexity of the staff and organization of IVASS does not allow the use of the current system ***APPLICATION.2 used by the Valencian Generalitat for socio-health personnel, as it does not adapt to the functions, shifts, organizational structure, and characteristics of the various services managed by IVASS. However, it has been implemented for the bureaucratic or administrative staff of IVASS.

Both reasons must be dismissed as a cause for exemption from the violations committed, since:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
21/43

-

On one hand, it is observed that it is true that the object of the tender was to develop a system for recording employee attendance that did not rely on biometric data, but according to IVASS, the tender was initiated in December 2023, more than 5 years after the GDPR came into effect.

-

A similar situation occurs with the adaptation of the ***APPLICATION.2 of the GVA, since IVASS itself, as a proactive responsible party for compliance with GDPR regulations, should have been aware of the complexity of the organizational structure, functions, and characteristics of the personnel that comprise its services, and should have assessed before the GDPR came into effect whether it was possible to extend this GVA tool to the personnel of its services.

Even acknowledging the complexity referred to by the defendant, it is understood that they had sufficient time to carry out the necessary evaluations and analyses and to make the necessary adaptations to their previous system, or to decide on the tender for a new attendance and work control system that would meet their specific needs, prior to the GDPR coming into effect.

In this regard, it should be noted that the GDPR was approved on April 27, 2016, so IVASS should have been aware that new obligations would be enforceable from May 25, 2018, the moment from which it would be fully applicable, thus having a period of more than two years to inform itself and ensure that the fingerprint system it was using complied with the requirements of the new GDPR. And in the event that its decision was to replace it with another attendance recording system that did not use biometric data, it would also have had more than two years to tender for a labor attendance recording system suitable for the new GDPR, or to adapt, if necessary, the aforementioned ***APPLICATION.2 to the particularities of the structure and functions of IVASS.

On the other hand, IVASS refers to the elimination of the fingerprint system, stating that: "IVASS has

proceeded to change the attendance recording system and definitively suspend all processing of personal data through a fingerprint system that the terminals of the current application have. Thus, on June 6, an informational note was sent to all staff of the entity to announce the change of the attendance recording system. In this way, instead of using the terminal reader (which has been disabled), attendance would be recorded generally, through an employee code and password entered into the terminal, until the tender for the new application.” However, this informational note from June 6 was not provided along with its allegations—nor at any other time prior to the issuance of the resolution proposal—nor was any other evidence presented that proved the definitive disabling of the fingerprint attendance recording system.

For this reason, the resolution proposal stated that IVASS made assertions but had not proven that the disabling of the fingerprint attendance recording system had occurred, when the system was replaced and by what method of attendance recording, and also noted that subsequent proof of these means would not imply exemption from liability:

“It should be noted that in the event that the defendant provided such proof during this procedure, it would only imply that the defendant

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/43

has complied with the provisional measure adopted in the initiation agreement, therefore no proceedings can be derived regarding the possible non-compliance with it. However, this would not exempt responsibility for the infringements that have already been committed, since they were consummated by continuing to process biometric data without meeting the aforementioned requirements demanded by the new GDPR during the period in which the system continued to operate from the time the GDPR came into force until it was abolished.”

It is therefore appropriate to confirm the conclusions reached by the Proposal for Resolution, dismissing the allegations against the initiation agreement, based on the following:

“Such arguments -if proven- could confirm, in their case, that the entity being claimed has complied with the corrective measures that were indicated in the initiation agreement and/or the provisional measure that was adopted in that agreement, but in no case can they be considered as grounds for exemption from the commission of the infringements that are attributed in the present procedure, since the abolition of this system and its replacement with another that does not involve the processing of biometric data was carried out after the initiation agreement, which means that the infringements were consummated and remained in effect continuously from the day the new GDPR came into force -when the new obligations of Articles 35, 38, and 9 of the same began to be enforceable- until a moment after the receipt of the initiation agreement of this procedure, which is not specified or evidenced, the entity being claimed merely mentioning that on June 6, 2024, it informed its staff that the previous timekeeping system is disabled. This implies that the infringements attributed in the present procedure were consummated on May 25, 2018, and persisted over time for more than 6 years.”

IV

Response to the allegations against the proposal for resolution

As reflected in the background of this resolution, in its allegations against the proposal for resolution, the entity being claimed reiterates the arguments already made in the initiation agreement of the sanctioning procedure; especially regarding its initiative to modify the working time control system, despite which the open tender was declared void, and regarding the modifications concerning the timekeeping system, which has now become one of user and password.

In these new allegations, and unlike what occurred during the initiation agreement:

- The IVASS provides as Document 1 the proof of having proceeded with the provisional replacement of the working time control system through fingerprint, providing both the communication addressed to its staff with instructions on how to clock in and the informative note from June 2024 regarding the disabling of the fingerprint timekeeping system subject to this sanctioning procedure. From its literal tenor -first proven fact- it follows that it is true that IVASS disabled the fingerprint timekeeping system

and
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
23/43

It communicated to its employees on June 6, 2024, that starting from June 10, 2024, it would begin using what it refers to as a "provisional timekeeping system" in its allegations, through which employees would manually record their working hours by entering a code into the terminals at their workplaces.

-

It is reported that -once the previous tender was declared void- a new tender is planned to implement a definitive timekeeping system that also does not employ biometric systems, insisting that the system implemented on June 10, 2024, is temporary, and indicating that a new technical specifications document is being prepared. It is noted that the technical specifications document provided in the initial agreement allegations referred to the previous tender that was declared void. However, the new specifications document is not provided, nor are details given regarding the new tender, so this Agency is unaware of what the referred system consists of.

-

In relation to the corrective measure concerning the DPD, new information is provided -which is not substantiated- referring to: (i) that on November 18, the proposal for resolution of the present procedure was communicated to the DPD of the Generalitat Valenciana; and (ii) that a technical figure has been established in IVASS for communication with the DPD of the Generalitat Valenciana regarding data protection.

-

It also comments on the corrective measure of preparing and overcoming a DPIA indicating that the General Directorate of IVASS has directly opted for the replacement of the previous model of attendance control through fingerprint scanning with a user-password numeric code timekeeping system in the various centers and resources of the network and by using the application ***APPLICATION.2 for personnel assigned to bureaucratic services. In this regard, and pending according to IVASS the tender for a new timekeeping system whose specifications are being prepared, this Agency is unaware if the designed processing will require the preparation and overcoming of the DPIA due to the inclusion of special category biometric data or being of high risk. In light of the above, the request for the non-imposition of any sanction made by IVASS should be dismissed, since the allegations to the proposal for resolution:

-

Are limited to claiming that it has complied with the corrective measures that had been mentioned in the initial agreement and proposal for resolution, without alleging or providing evidence regarding not having committed the infractions attributed in this procedure between the entry into force of the GDPR and June 10, 2024, acknowledging that it has applied a fingerprint timekeeping system without any exception from Article 9.2, nor preparing and overcoming a prior DPIA, nor consulting the DPD of the GVA. Therefore, the infractions are consummated and must be subject to sanction, as the proposal for resolution rightly indicated. The fact that it has been able to replace the fingerprint timekeeping system with another that does not require biometric data also confirms that the option of fingerprint timekeeping, thus using special category personal data, was not the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
24/43

the only possibility to achieve the completion of time control since it is reported that a clocking system by user and password has been established,

-

And regarding the corrective measures, it is appropriate to maintain the pronouncement of the same in the resolution, since IVASS states that the system it has been using since June 10, 2024 - based on the manual entry of a code by the employee at a terminal - is provisional, and that it is designing a new clocking system (non-biometric) to be implemented definitively. Therefore, the measures will remain in effect until it is confirmed that the definitive clocking system that is ultimately implemented has been carried out with the participation of the DPD, does not involve the processing of biometric data, or that in the event of doing so, complies with the other requirements that the GDPR demands for the processing of biometric data (such as the exception in Article 9.2, and the DPIA in Article 35, which implies that biometric processing is necessary, proportional, and suitable, with no less intrusive alternatives existing that allow for the pursued purpose).

V

Assessment of the evidence

To adopt the resolution of this procedure, the documentation provided by the responding entity in the 3 submissions presented in this procedure dated March 4, March 21, and June 18, 2024, has been assessed, obtaining the following conclusions in this regard:

-

In its two responses to the transfer of the complaint dated March 4 and March 21, 2024, the following are presented:

As Documents 1 and 2, a Report from ***COMPANY.1 dated January 19, 2024, on the interpretation of the Guide to biometric processing published in November 2023 regarding this Agency, and the Informative Note issued by the application designed by ***COMPANY.2, which is ***APPLICATION.1. Document 3 is attached, which is a Report from the DPD of the GVA dated March 5, 2024, requested by IVASS to respond to the transfer of the complaint that gives rise to this procedure, in which the DPD states that the treatments for controlling working hours through biometric systems are subject to the legal regime regarding data protection, and requests the submission of the technical specifications of the program in order to conduct a deeper analysis, also noting that in the event of implementing fingerprint biometric treatments, certain mandatory documentation must be submitted, including a prior risk analysis and the preparation of a Data Protection Impact Assessment (hereinafter, DPIA), in addition to verifying the facts subject to the complaint, and reviewing whether a legal basis exists. Document 4 is attached, which is an offer with commercial information about the program ***APPLICATION.1, a time and personnel management platform that the respondent claims to have obtained from the entity with which it contracted the same, on March 21, 2024.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/43

And finally, Document 5 is attached, which is the new report from the DPD of the GVA dated March 11, 2024, addressed to IVASS, which, after analyzing the aforementioned Offer and documentation from ***PLATAFORMA.1, concludes as follows:

“2. Among other issues, it determines that IVASS has misinterpreted that the contracted system does not make use of biometric data, when the template obtained from a fingerprint is in itself a biometric data. This observation is based on the fact that the fingerprint scanner captures unique patterns in each fingerprint, such as arches, loops, and whorls. These patterns are translated into a series of numbers and codes that form the biometric fingerprint template (number).”

3.- The offer provided by the awarded company does not offer information or assessment regarding the use or non-use of biometric data by its timekeeping control system, so IVASS only has the aforementioned informational note, from which it has been incorrectly interpreted that the system does not make use of biometric data, since the terms in which it has been drafted are directed to ensure that the affected individuals consider it as such. However, it has already been documented in the previous section that this is not the case, as the template obtained from a fingerprint is a biometric data.

4.- Therefore, it is the recommendation of this delegation that IVASS should reconsider the request from the AEPD, taking into account both the guidelines of the first report sent to them on March 5 by

this delegation, as well as the content of section 2 of this report and the rest of the observations.” From the analysis of the aforementioned documents, it is concluded that IVASS has been processing biometric data since 2010, since, as the DPD of the GVA correctly points out in the two mentioned reports, IVASS incorrectly interpreted that ***PLATAFORMA.1, which it had contracted, did not process biometric data, based on what was stated in the Informational Note directed to the users of the Program for their reassurance, which indicated that the record did not store the fingerprint but rather an alphanumeric code obtained from that fingerprint, which is precisely the biometric template of the fingerprint, which is undoubtedly considered biometric data.

Thus, as the DPD rightly points out in its latest report, the biometric template is precisely this alphanumeric code referred to in the informational note. It is indicated in this regard that: “The operating protocol of biometric systems is usually as follows:

- The fingerprint is converted into a biometric template (number) that is stored in the timekeeping system or in a device such as a card that becomes the property of the employee.
- The fingerprint scanner captures unique patterns in each fingerprint, such as arches, loops, and whorls. These patterns are translated into a series of numbers and codes that form the biometric fingerprint template (number).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
26/43

- The template obtained by the sensor is compared with the template stored in the timekeeping system or on a device, and only the time entry associated with the person whose templates match is recorded.”

The lack of awareness by the respondent that the biometric template obtained from the program is a biometric data, and their failure to thoroughly analyze the technical specifications of the program, which were not provided in this procedure nor to their own DPO, indicates a serious lack of diligence required of any data controller under the Principle of Proactive Responsibility set forth in Article 24 of the GDPR. This is firstly because the conclusion reached was based solely on analyzing this Informative Note, and not the technical specifications of the program (which were neither provided to their DPO nor in this procedure), and secondly because even upon analyzing the content of the aforementioned note, it is clearly evident that what the program stores is a biometric template (an alphanumeric code obtained from the fingerprint), and that this is biometric data. This is a fact that they should have been aware of due to their role as data controller, and they would have known had they consulted with their DPO once it was appointed following the entry into force of the GDPR.

Thus, although it is true that initially IVASS maintained in its first response to the transfer from this Agency on March 4, 2024, that its program did not process biometric data, following its second letter dated March 21, 2024, after requesting and receiving the aforementioned reports from the DPO, IVASS implicitly acknowledges that it has processed biometric data, limiting itself from then on to informing about the corrective measures it has planned or adopted to replace its timekeeping/work registration system with another that does not process biometric data. This implies an implicit acknowledgment that the previous system indeed processed biometric data from 2010 until its alleged elimination in June 2024.

However, despite the requests made by the GVA DPO on two occasions, and what is indicated in the initiation agreement of the present file, the respondent makes no mention of or provides evidence of having complied with the requirements necessary to process biometric data referred to in Articles 35, 38, and 9 of the GDPR, as it does not provide any DPIA, nor does it demonstrate or state that it consulted its DPO prior to the present procedure, having even ignored the recommendations obtained following Report ***EMPRESA.1 dated January 19, 2024, as the DPO rightly points out in their report. The same can be said regarding the existence of an exception under Article 9.2 that would allow it to process biometric data following the entry into force of the new GDPR. There are no references to the non-compliance with these requirements.

- Documents submitted in the written allegations to the initiation agreement.

In the written allegations to the initiation agreement, the respondent entity continues to fail to provide evidence or mention compliance with the requirements whose violation implies the commission of the three infringements attributed in the present procedure. Starting from the fact that ***PLATAFORMA.1 used since 2010 does indeed process biometric data, the respondent limits itself to informing about the corrective measures adopted and the replacement of this system with another that does not process biometric data.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
27/43

And the evidence provided refers to substantiating these corrective measures and the reasons why the replacement of the system could not be carried out earlier.

Thus, in the written allegations to the initiation agreement, the following documents are submitted, which are evaluated as follows:

-
Document 1. Technical Specifications of the tender for “***REFERENCE.1, processed under the establishment of the dynamic acquisition system of the purchasing center of the Generalitat, ***REFERENCE.2, for the contracting of the supply under a rental regime of a software package in SAAS mode, which includes a comprehensive time tracking system for time control, work shift planning, and maintenance for the centers and services of IVASS,” which according to IVASS began in December 2023 and has been declared void due to the lack of competing companies. From the examination of these specifications, it is evident that IVASS has attempted to tender a system that does not use biometric methods, as this is imposed as a condition of the tender. However, it is not substantiated either the date on which the tender began or that it has been declared void. It must be stated that, even in the best-case scenario, if it were true that the tender was issued in December 2023 and has been declared void, this would imply that when the tender began, IVASS had already been processing biometric data for over 5 years without complying with the requirements referred to in this procedure, meaning that the infringements were already consummated.

-
Document 2. User manual of the Program ***APPLICATION.2 of the GVA, by which the registration of working hours and time control of its administrative staff is carried out. This document does not pertain to the subject of this procedure, as it has not been used by IVASS, according to its own statement, and had it been used, it would have also been after the infringements attributed in this procedure were consummated, thus lacking probative relevance.

-
Document 3. Informative letter addressed by the DPD of the GVA to the general secretaries of the administrations of the GVA, dated March 27, 2024, informing of the need for the DPD to serve as a point of contact with the protection authorities, such as the present Agency. This document again does not exempt from the commission of the infringements concerning this procedure, nor does it allow for the substantiation that corrective measures related to the duty to consult and involve the DPD have been adopted, since the letter was sent by the DPD and not by IVASS, and does not establish any protocol for the consultation and participation of the DPD in all matters of data protection regulation, as was stated in the corrective measures of the initiation agreement.

-
Documents submitted in the allegations to the resolution proposal.
It should be noted, as already mentioned in response to the aforementioned allegations, that the respondent claimed to have sent a communication to its staff at C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
28/43

dated June 6, 2024, which informs that the fingerprint clocking system through ***PLATFORM.1

***COMPANY.3 was not provided at the time it was reported to this AEPD but rather later, in the allegations to the proposed resolution issued.

This document allows for the substantiation of the fact alleged by IVASS that the fingerprint clocking system has been removed or disabled since June 10, 2024, a date that appears in the communication as the starting date from which the new system should be employed. This should be understood as a new proven fact, and it has been noted as such in the first proven fact. However, as indicated in the previous Legal Basis, given that it is stated that this system is provisional and that a new definitive clocking system is being tendered, the adoption of corrective measures must be maintained until it is substantiated what this new definitive system is, and evidence is provided of having complied with the rest of the corrective measures imposed in this Resolution.

In summary, from the assessment of the evidence provided, it is deduced that the respondent has been processing biometric data since 2010 by contracting ***PLATFORM.1 (***COMPANY.3) for the recording of working hours of its employees through fingerprint, and that after the GDPR came into effect on May 25, 2018, at which point biometric data was elevated to a special category and classified as high-risk processing, IVASS did not act with the diligence required of a data controller to ensure that its fingerprint-based working hours clocking system complied with the requirements arising from this new regulation, nor did it proceed to remove it and initiate the necessary procedures to replace it with another that adapts to the new GDPR until it became aware of the filing of the complaint with this Agency.

VI

Unfulfilled obligation.

Art. 35 Data Protection Impact Assessment

6.1. On the necessity to conduct and surpass a DPIA.

As previously stated, before implementing or continuing with a data processing platform based on such intrusive technology as the program “***PLATFORM.1” that the respondent contracted with ***COMPANY.2 (now ***COMPANY.3) to enable the clocking of its personnel's working hours, it is also necessary to audit its operation beforehand, not in isolation but within the framework of the specific processing in which it will be used (in this case, daily recording of working hours for IVASS employees).

The data protection impact assessment, DPIA, has appeared since the entry into force of the GDPR as a new tool required of controllers of “high-risk” processing to ensure compliance with this aspect of processing, as established in Article 35, paragraph 1 of the GDPR:

“When it is likely that a type of processing, in particular if it uses new technologies, by its nature, scope, context, or purposes, entails a high risk to the rights and freedoms of natural persons, the controller of the processing...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

29/43

will carry out, prior to the processing, an assessment of the impact of the processing operations on the protection of personal data...”

As already indicated, the processing of biometric data has been included in the List of processing operations considered to be of high risk by the AEPD, pursuant to the provisions of Article 35.4 of the GDPR, so we must start from the premise that the processing of biometric data implemented by IVASS should have been preceded by a valid impact assessment, which included at least the sections provided for in Article 35.7 of the GDPR. This implies that it is not enough to carry out a DPIA; it must be passed in order to comply with the GDPR.

This assessment will be carried out prior to the commencement of processing, but it should be understood as a continuous or periodic assessment, in the sense established by Article 35.11 of the GDPR, which states: “Where necessary, the controller shall examine whether the processing is in accordance with the data protection impact assessment, at least when there is a change in the risk posed by the processing operations.” Based on this, it is understood that, if the assertion made by

IVASS that the processing began in 2010 when the platform was contracted is confirmed, the processing of biometric data carried out through it must have complied with the requirements set forth in the previous personal data protection regulations, and, above all, it must have been reviewed with the entry into force of the GDPR in May 2018, conducting and passing the corresponding DPIA from then on.

A DPIA must meet the minimum requirements or content outlined in Article 35.7 of the GDPR, which states:

“The assessment shall include at least:

- a) a systematic description of the envisaged processing operations and the purposes of the processing, including, where applicable, the legitimate interests pursued by the controller;
- b) an assessment of the necessity and proportionality of the processing operations in relation to their purpose;
- c) an assessment of the risks to the rights and freedoms of data subjects referred to in paragraph 1, and
- d) the measures envisaged to address the risks, including safeguards, security measures, and mechanisms to ensure the protection of personal data, and to demonstrate compliance with this Regulation, taking into account the rights and legitimate interests of data subjects and other affected persons.”

In short, passing a DPIA requires that the controller of a high-risk processing operation documents in writing that it surpasses the assessment of suitability, necessity, and proportionality of the processing, and that it manages the specific risks of the processing from the design stage, with the practical application of measures aimed at them in such a way as to ensure an acceptable risk threshold throughout the entire lifecycle of the processing, as established in Article 35 of the GDPR.

Furthermore, it obliges prior consultation with the supervisory authority in cases where the controller has not taken measures to mitigate the risk in accordance with Article 36 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

30/43

In this case, there is evidence that the entity being claimed:

- Initiated in 2010 a biometric data processing by implementing a time tracking system through fingerprint detection for IVASS employees, and when the new GDPR came into effect, continued with the biometric tracking system without conducting a prior DPIA in accordance with the provisions of Article 35 of the GDPR. This was based on the understanding that the informative note of the program indicated that the program did not process biometric data.

- Was aware of the report prepared by ***COMPANY.1 dated January 19, 2024, which recommended the preparation and completion of a prior DPIA for biometric processing, but did not take its recommendations into account.

The DPO informed them on March 5, 2024, and March 11, 2024, following the criteria of this Agency, about the necessity of conducting a DPIA that analyzed the concurrent risks, the necessity-suitability, and proportionality of the processing compared to other possible methods of time tracking, and foresee the appropriate measures to address such risks.

Finally, in their written responses to the transfer, the respondent did not express their intention to prepare and complete a DPIA that analyzes the biometric data processing currently being carried out at IVASS through the program ***PLATFORM.1, as recommended by the DPO. In their written allegations regarding the initiation agreement, they inform that they have switched to a system that does not involve the processing of biometric data in the future, having proceeded to eliminate the use of the previous system.

6.2. Regarding the requirement that the processing of biometric data is necessary, suitable, and proportional.

Not having conducted and completed the mandatory DPIA in this case means, among other things, that IVASS acknowledges that it has been processing biometric data of its employees since it

implemented the time tracking control system through fingerprint detection, and that it has continued with the same until now without having previously conducted the assessment of its necessity, suitability, and proportionality as required by Articles 5.1.c) and 35.4.b) of the GDPR. This assessment is part of the content of the DPIA and continues to be unaddressed at present.

Thus, Article 5.1.c) of the GDPR includes the so-called "Principle of data minimization," which states the following:

"1. Personal data shall be:

a) adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed ('data minimization')."

It is noteworthy that, especially since the entry into force of the GDPR, respect for this principle must be the starting point for the initiation of any processing, and the controller must consider whether this processing will truly be necessary, suitable, and proportional before starting or continuing with it in this case. Therefore, the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

31/43

Systems that used biometric processing for employee time tracking before the entry into force of the GDPR must have conducted this prior analysis before continuing with the processing of personal data, an analysis that must be documented within the DPIA when there is a likelihood that the processing entails a high risk (as is the case with biometrics processed in this time tracking control system). Thus, the DPIA must contain, in addition to other aspects, "b) an assessment of the necessity and proportionality of the processing operations concerning their purpose," in accordance with Article 35.7. b) of the GDPR.

This is confirmed by Recital 39 of the GDPR, which emphasizes the importance of the processing being necessary, stating that "Personal data should only be processed if the purpose of the processing cannot reasonably be fulfilled by other means."

In the same vein, the Article 29 Working Party expresses itself in its Opinion 3/2012 on the evolution of biometric technologies.

The obligation to process only "personal data that is adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed," as provided by the principle of data minimization under Article 5.1.c) of the GDPR, and to assess the necessity and proportionality of the processing in the DPIA according to Article 35.7 b) of the GDPR, must be interpreted in accordance with the provisions of the repeated jurisprudence of our Constitutional Court regarding the necessity of verifying that any restrictive measure of fundamental rights (processing operations that include biometric and geolocation data in this case) exceeds what is referred to as "the triple test of proportionality."

This implies that, first and foremost, it is necessary to ascertain whether it meets the three following requirements or conditions referred to by the Constitutional Court: "whether such a measure is capable of achieving the proposed objective (suitability test); whether, in addition, it is necessary, in the sense that there is no other more moderate measure to achieve such a purpose with equal effectiveness (necessity test); and, finally, whether it is balanced or proportionate, as it derives more benefits or advantages for the general interest than harms to other conflicting goods or values (strict sense proportionality test)."

In the present case, there is no evidence that IVASS conducted an assessment of this necessity, suitability, and proportionality once the GDPR came into force. This is a prior and initial requirement, without which it is not possible to continue with the processing of biometric data nor could the minimum requirements for approving a valid DPIA be met, since the processing of personal data that is not necessary, suitable, and proportional is prohibited by the GDPR.

Moreover, in addition to the absence of this prior triple test of proportionality, it should be noted that there is no evidence in the proceedings that the biometric time tracking system through fingerprinting was necessary to fulfill the purpose of labor time control for which it was implemented.

This is so because, in the matter of labor time registration, there are and were other less intrusive time tracking systems that allowed compliance with the requirements.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
32/43

intended purpose with lower risks for the interested parties, such as magnetic cards, web connection, or signature sheets that are common and easy to implement by employers, especially within the public sector. However, the entity being claimed has not provided any analysis that allows for the dismissal of other alternative means of recording and controlling working hours that are less invasive.

Moreover, the entity being claimed states in section seven of its allegations regarding the initiation agreement, concerning compliance with the provisional measure of suspension of biometric data processing agreed upon, the following:

“In accordance with the provisions of Article 69 of the LOPDGDD and Article 56 of the LPACAP, and as already pointed out in the fifth allegation, IVASS has proceeded to change the clocking system and the definitive suspension of all personal data processing through a clocking system by reader that the terminals of the current application possess.

Thus, on June 6, an informative note was sent to the entire staff of the entity to announce the change of the clocking system. In this way, instead of using the terminal reader (which has been disabled), clocking would be done generally through an employee code and password entered into the terminal, until the tender for the new application.”

Therefore, between the notification of the provisional measure produced on June 4, 2024, and the day it was notified (June 6, 2024) and the implementation of the change in the clocking system (June 10, 2024), only two and six days elapsed, respectively, which implies that IVASS has been able to seemingly easily and in a short period of time establish an alternative working hours clocking system that does not involve the processing of biometric data. Thus, it is also confirmed that there were indeed less intrusive and equally suitable alternatives to enable the unique identification of employees who register their working hours.

In conclusion, it is considered that the facts presented violate what is established in Article 35 of the GDPR, for not conducting and exceeding IVASS a prior DPIA before the initiation of the clocking treatment of working hours through fingerprint used by its employees.

VII

Classification and qualification of the infringement of Article 35 of the GDPR.

As stated, it is considered that the facts presented violate what is established in Article 35 of the GDPR, which constitutes the commission of an administrative infringement classified in Article 83.4.a) of the GDPR which indicates that:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total global annual turnover of the previous financial year, opting for the higher amount:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
33/43

a)

The obligations of the data controller and the data processor pursuant to Articles 8, 11, 25 to 39, 42, and 43.”

For the purposes of prescription, the LOPDGDD establishes in its Article 73.t) that: “In accordance with what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a two-year limitation period: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

t) The processing of personal data without having carried out the impact assessment of the processing operations on the protection of personal data in cases where it is required.”

VIII

Unfulfilled obligation. On the prohibition of processing special category data under Article 9 of the GDPR

As previously mentioned, since the entry into force of the GDPR, according to Article 9.1 of the GDPR, the processing of biometric data is prohibited when they are: “biometric data intended to uniquely identify a natural person,” as a general rule, so another requirement for this type of biometric data processing is that prior to commencing the processing, the data controller must also verify and demonstrate that one of the exceptions provided for in Article 9.2 of the GDPR or other specific legislation applies, which enables them to carry out such processing for the specific purpose in question (in this case, the registration and control of the working hours of IVASS employees). It should be noted that, while the processing is generally prohibited, any exception to this prohibition must be interpreted restrictively. This is deduced from recitals 51 and 52 of the GDPR.

In this context, the exceptions that could possibly allow for the lifting of the general prohibition on processing biometric data aimed at identifying/verifying the identity of natural persons are those provided for in Article 9.2 of the GDPR, with the following literal wording, which must be interpreted restrictively, always in favor of protecting the rights and freedoms of citizens in case of doubt:

“2. Paragraph 1 shall not apply when one of the following circumstances applies:

- a) the data subject has given explicit consent to the processing of such personal data for one or more specified purposes, except where Union or Member State law provides that the prohibition referred to in paragraph 1 may not be lifted by the data subject;
- b) the processing is necessary for compliance with a legal obligation to which the data controller is subject or for the exercise of rights in the field of employment law and social security and protection, to the extent that such processing is authorized by Union or Member State law.
- c) the processing is necessary to protect the vital interests of the data subject or of another natural person, in the event that the data subject is not physically or legally capable of giving consent;
- d) the processing is carried out, in the course of its legitimate activities and with appropriate safeguards, by a foundation, an association, or any other body without

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
34/43

profit motive, whose purpose is political, philosophical, religious, or trade union-related, provided that the processing refers exclusively to current or former members of such organizations or to individuals who maintain regular contacts with them in relation to their purposes and provided that the personal data is not communicated outside of them without the consent of the data subjects;

- e) the processing refers to personal data that the data subject has made manifestly public;
- f) the processing is necessary for the formulation, exercise, or defense of claims or when courts act in the exercise of their judicial function;
- g) the processing is necessary for reasons of essential public interest, based on Union law or the laws of the Member States, which must be proportional to the objective pursued, respect the right to data protection in essence, and establish adequate and specific measures to protect the interests and fundamental rights of the data subject;
- h) the processing is necessary for purposes of preventive or occupational medicine, assessment of the worker's capacity, medical diagnosis, provision of health or social care assistance or treatment, or management of health and social care systems and services, based on Union law or the laws of the Member States or pursuant to a contract with a health professional and without prejudice to the conditions and guarantees provided for in paragraph 3;
- i) the processing is necessary for reasons of public interest in the area of public health, such as protection against serious cross-border threats to health, or to ensure high standards of quality and

safety of health care and of medicines or medical products, based on Union law or the laws of the Member States that establish adequate and specific measures to protect the rights and freedoms of the data subject, in particular professional secrecy.

j) the processing is necessary for archiving purposes in the public interest, for scientific or historical research purposes, or for statistical purposes, in accordance with Article 89, paragraph 1, based on Union law or the laws of the Member States, which must be proportional to the objective pursued, respect the right to data protection in essence, and establish adequate and specific measures to protect the interests and fundamental rights of the data subject.”

Therefore, in addition to not having carried out a valid DPIA, if the controller does not demonstrate that its processing falls within any of these exceptions, it will incur a violation of Article 9 of the GDPR by initiating prohibited processing.

In the present case, it is established that the entity in question did not act with the diligence required of a data controller and mistakenly believed that it was not processing personal biometric data by using the fingerprint clocking method, and thus did not consider it necessary to meet one of these exceptions. It claims to have replaced it with another method that does not process biometric data, disabling clocking through fingerprinting, and communicated this to its staff in June 2024.

Nevertheless, it provides no evidence nor makes any mention of the existence of one of these exceptions during the period in which the processing based on fingerprint clocking was operational. Neither in its last written response to the communication of March 21, 2024, nor in its allegations regarding the initiation agreement or the proposed resolution, is there any mention of the existence of any exception that would allow it to process biometric data, up to

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

35/43

on suppression and substitution. And this is despite the fact that the initiation agreement detailed the reasons why it was understood that IVASS has a lawful basis under Article 6.1 of the GDPR that enables it to process personal data for the purpose of monitoring the compliance of its employees' working hours, but that in the case of using a system that processes biometric data, as is the case here, it must also demonstrate that an exception under Article 9.2 of the GDPR applies, which lifts the prohibition on processing such biometric data.

Therefore, since the exception for the processing of biometric data related to the fulfillment of a legal obligation provided for in Spanish law does not apply, nor has the existence of any other exception provided for in Article 9.2 of the GDPR been demonstrated, it is considered that the processing also incurred an administrative infringement of Article 9 of the GDPR.

In any case, having made these clarifications, it should be noted that in the present case, since the entity being claimed has not demonstrated the existence of any of the exceptions provided for in Article 9.2 of the GDPR that would allow it to lift the general prohibition on the processing of biometric data between the entry into force of the GDPR and its alleged suppression, in light of the evidence available and following the investigation carried out, it is considered that the processing carried out through the biometric timekeeping system used by IVASS constitutes an administrative infringement of Article 9 of the GDPR.

IX

Classification and qualification of the infringement of Article 9 of the GDPR

As stated in Legal Basis VII, in accordance with the evidence currently available, it is considered that the facts presented violate the provisions of Article 9 of the GDPR, which could constitute the commission of an administrative infringement classified under Article 83.5 of the GDPR, which states the following:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

“a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9.”

For the purposes of prescription, the LOPDGDD establishes in its Article 72.e):

“Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall prescribe after three years, which involve a substantial violation of the articles mentioned therein and, in particular, the following:

“e) The processing of personal data of the categories referred to in Article 9 of Regulation (EU) 2016/679, without any of the circumstances provided for in that provision and in Article 9 of this organic law applying.”

X

On the obligation of participation of the DPO provided for in Article 38 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

36/43

Another significant novelty that makes the GDPR a paradigm shift in data protection is its configuration as a modernized framework based on accountability for the protection of personal data in Europe, where data protection officers (DPOs) are the central element, facilitating compliance with the provisions of the GDPR by the data controller and processor.

Around this idea, Articles 37 to 39 of the GDPR regulate the circumstances in which their designation is mandatory, the possibility of voluntarily appointing them, obligations such as publishing their contact details and communicating them to the supervisory authority, as well as their position and functions within the organization for which they are appointed.

Specifically, and regarding the present file, it is pertinent to refer to what is established in Article 38 of the GDPR, concerning the "Position of the data protection officer," which states the following:

1. The data controller and the data processor shall ensure that the data protection officer is involved appropriately and in a timely manner in all issues related to the protection of personal data.
2. The data controller and the data processor shall support the data protection officer in the performance of the functions mentioned in Article 39, providing the necessary resources for the performance of these functions and access to personal data and processing operations, and for maintaining their specialized knowledge.
3. The data controller and the data processor shall ensure that the data protection officer does not receive any instructions regarding the performance of these functions. They shall not be dismissed or penalized by the controller or processor for performing their functions. The data protection officer shall report directly to the highest hierarchical level of the controller or processor.
4. Data subjects may contact the data protection officer regarding all issues related to the processing of their personal data and the exercise of their rights under this Regulation.
5. The data protection officer shall be obliged to maintain secrecy or confidentiality regarding the performance of their functions, in accordance with Union law or the laws of the Member States.
6. The data protection officer may perform other tasks and duties. The controller or processor shall ensure that such tasks and duties do not lead to a conflict of interest.

In this regard, the W243 Guidelines on Data Protection Officers from the Article 29 Working Party, adopted on December 13, 2016, and revised on April 5, 2017, emphasize the importance of the obligation that the controller has to ensure this participation, consulting the DPO of their organization.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

37/43

organization before making decisions that affect data protection in a prior and appropriate manner for each processing of personal data that it intends to carry out.

“3.1. Participation of the DPO in all matters related to personal data protection Article 38 of the GDPR

establishes that the controller and the processor shall ensure that the DPO "participates adequately and in a timely manner in all matters related to personal data protection."

It is essential that the DPO, or their team, participate from the earliest possible stage in all matters related to data protection. Regarding impact assessments related to data protection, the GDPR expressly provides for the early involvement of the DPO and specifies that the controller shall seek the advice of the DPO when conducting such an impact assessment. Ensuring that the DPO is informed and consulted from the outset will facilitate compliance with the GDPR, promote a privacy-by-design approach, and therefore should be a standard procedure in the governance of the organization. Furthermore, it is important that the DPO is considered a stakeholder within the organization and is part of the relevant working groups dealing with data processing activities within the organization. Consequently, the organization must ensure, for example, that:

- The DPO is regularly invited to participate in meetings with senior and middle management.
- It is recommended that the DPO is present when decisions are made that have implications for data protection. All relevant information must be communicated to the DPO in a timely manner so that they can provide appropriate advice.
- The opinion of the DPO is always duly taken into account. In case of disagreement, the Working Group recommends, as good practice, documenting the reasons for not following the DPO's advice.
- The DPO is consulted promptly once a data security breach or any other incident has occurred. When relevant, the controller or the processor may develop guidelines or programs on data protection that determine when the DPO should be consulted."

It is recorded in the file that the DPO of the Generalitat Valenciana, which is the autonomous administration to which IVASS is attached, was not consulted by IVASS regarding the aforementioned processing of recording and controlling the working hours of employees that IVASS was employing through a fingerprint system. It is also noted that IVASS did not designate its own DPO and involve them regarding this processing.

That is, there is no record of the participation of a DPO, nor the prior consultation of IVASS with the DPO of the GVA or one that could have been designated by it when the new GDPR came into effect, nor subsequently when the report ***EMPRESA.1 of January 19, 2024, was received. Furthermore, there is also no record that IVASS consulted a DPO before responding to the request made by the claimant on December 13, 2023, in which they requested the deletion of their fingerprint and a change to a paper and pen timekeeping system or any other means of attendance control that does not involve the processing of biometric data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

38/43

In light of the documentation provided in the procedure, it is deduced that the DPD of the GVA was not aware of the biometric system implemented by IVASS until it was consulted in February of this year 2024 by the respondent following the request made by this Agency in connection with the present procedure. Once consulted, the DPD did not hesitate to issue two reports on March 5 and 11, 2024, where it examined the implemented system, determining that it is a biometric processing, that the respondent had misinterpreted the documentation obtained from the data processor that developed ***PLATAFORMA.1, and that it was necessary to comply with the obligation to carry out and surpass a prior DPIA, as well as to demonstrate the existence of a lawful basis, exception, and the rest of the principles and obligations provided for in the data protection regulations.

On the other hand, although in its allegations to the proposed resolution the respondent already refers to the possible designation of its own DPD, to whom it may have consulted on these matters, it still fails to prove that it has designated one, that it has consulted them about the new system that is pending tender, or, if applicable, that the DPD of the GVA is participating in it.

Consequently, it is considered that the known facts would constitute an infringement of Article 38.1 of the GDPR, which assigns the data controller the duty to ensure that the DPD participates adequately and in a timely manner in all matters relating to the protection of personal data.

XI

Typification and qualification of the infringement of Article 38 of the GDPR.

The violation of Article 38 of the GDPR is typified in Article 83.4.a) of the aforementioned GDPR in the following terms:

“4. Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43.”

For its part, the LOPDGDD in its Article 73, for the purposes of prescription, qualifies as “Serious Infringements:

According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall prescribe after two years:

w) Failing to enable the effective participation of the data protection officer in all matters relating to the protection of personal data, failing to support them, or interfering with the performance of their duties.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

39/43

XII

Proposal for sanction

Article 83 “General conditions for the imposition of administrative fines” of the GDPR in its paragraph 7 establishes:

“Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State.”

Likewise, Article 77 “Applicable regime for certain categories of controllers or processors” of the LOPDGDD provides that:

“1. The regime established in this article shall apply to the processing for which they are responsible or to which they are processors:

a) The constitutional bodies or those with constitutional relevance and the institutions of the autonomous communities analogous to them.

b) The judicial bodies.

c) The General Administration of the State, the Administrations of the autonomous communities, and the entities that make up the Local Administration.

d) The public bodies and entities of public law linked to or dependent on the Public Administrations.

e) The independent administrative authorities.

f) The Bank of Spain.

g) The public law corporations when the purposes of the processing relate to the exercise of public law powers.

h) The public sector foundations.

i) The Public Universities.

j) The consortia.

k) The parliamentary groups of the General Courts and the legislative assemblies of the autonomous communities, as well as the political groups of the Local Corporations.

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution declaring the infringement and establishing, where appropriate, the measures that should be adopted to cease the conduct or correct the effects of the infringement that has been committed, with the exception of that provided for in Article 58.2.i of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
40/43

The resolution will be notified to the person responsible or in charge of the processing, to the body to which they hierarchically depend, if applicable, and to the affected parties who had the status of interested parties, if applicable.

3. Without prejudice to the provisions of the previous section, the data protection authority will also propose the initiation of disciplinary actions when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied will be those established in the legislation on disciplinary or sanctioning regime that is applicable.

Furthermore, when the violations are attributable to authorities and executives, and it is proven that there are technical reports or recommendations for the processing that have not been duly addressed, the resolution imposing the sanction will include a reprimand naming the responsible position and will order the publication in the Official State Gazette or the corresponding regional gazette.

4. The resolutions related to the measures and actions referred to in the previous sections must be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article will be communicated to the Ombudsman or, where appropriate, to the analogous institutions of the autonomous communities.

According to the Regulation on the organization and functioning of the Vice-Presidency and Department of Equality and Inclusive Policies

(http://www.dogv.gva.es/datos/2017/01/27/pdf/2017_633.pdf), and the Ninth Additional Provision of Law 7/2021, of December 29, of the Generalitat, on fiscal measures, administrative and financial management, and organization of the Generalitat 2022 (DOGV No. 9246 / 30.12.2021), the entity in question is a public law entity with its own legal personality, attached to the aforementioned Vice-Presidency and Department of the Generalitat Valenciana, which is called the "Valencian Institute of Social Services" (IVASS). This has been confirmed by the entity in its written allegations regarding the initiation agreement.

Therefore, since the person responsible for the processing belongs to the autonomous administration, it is appropriate to issue a resolution declaring the infringement of Article 35 of the GDPR, Article 9 of the GDPR, and Article 38, by IVASS.

XIII

Adoption of corrective measures.

If the infringement is confirmed, it may also be agreed to impose on the responsible party the adoption of appropriate measures to adjust their actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified period..."

In this regard, considering that it has been proven by IVASS that the fingerprint timekeeping system has been replaced by another non-biometric system since June 10, 2024, but that the tender for another definitive system is pending, it must...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
41/43

corrective measures shall be adopted that would consist of carrying out and certifying to this Agency within a period of 7 months the compliance with the following corrective measures:

- Certify that it has definitively replaced the system used for the registration of the working hours of its employees with another that does not involve the processing of biometric data - providing the specifications, the contract finally signed with the contractor, and the technical documentation that

describes the new system used.

- In the event of continuing with the processing of biometric data, IVASS must carry out and complete a DPIA (Data Protection Impact Assessment), with the appropriate participation of the DPO (Data Protection Officer), which contains a prior risk analysis, and the evaluation of the triple test of suitability, necessity, and proportionality of the processing currently carried out for the registration and control of the working hours of its employees using biometric timekeeping systems, determining whether any of the exceptions in Article 9.2 of the GDPR apply, as well as the appropriate protective measures, and the other obligations required by personal data protection regulations.

- Certify that it has established an appropriate protocol or mechanism that ensures the participation of the DPO - providing the act of appointment of the DPO of IVASS in case it has occurred - in a timely manner in all matters related to data protection that arise in IVASS.

It is warned that failure to comply with the possible order to adopt measures may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Article 83.5 and 83.6, which may lead to the initiation of a subsequent sanctioning administrative procedure.

It is warned that failure to comply with the order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Article 83.5 and 83.6, which may lead to the initiation of a subsequent sanctioning administrative procedure.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE that the VALENCIAN INSTITUTE OF SOCIAL SERVICES (IVASS), with NIF Q4601042G, has infringed the provisions of Article 9 of the GDPR, an infringement classified in Article 83.5.a) of the GDPR and the provisions of Articles 35 and 38 of the GDPR, infringements classified in Article 83.4.a) of the GDPR.

SECOND: TO ORDER the VALENCIAN INSTITUTE OF SOCIAL SERVICES (IVASS), with NIF Q4601042G, that pursuant to Article 58.2.d) of the GDPR, within seven months from the date this resolution becomes final and enforceable, to certify that it has proceeded to comply with the following corrective measures:

- Certify that it has definitively replaced the system used for the registration of the working hours of its employees with another that does not involve the processing of biometric data - providing the specifications, the contract finally signed...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

42/43

signed with the awardee and the technical documentation that describes the new system used.

-

In the event of continuing with the processing of biometric data, IVASS must carry out and pass a DPIA (Data Protection Impact Assessment), with the appropriate participation of the DPO (Data Protection Officer), which includes a prior risk analysis, and the evaluation of the triple judgment of suitability, necessity, and proportionality of the processing currently carried out for the registration and control of the working hours of its employees using biometric timekeeping systems, determining whether any of the exceptions in Article 9.2 of the GDPR apply, as well as the appropriate protective measures, and the other obligations required by personal data protection regulations.

-

They must demonstrate that they have established an appropriate protocol or mechanism that ensures the participation of the DPO, -providing the appointment act of the DPO of IVASS in case it has occurred- in a timely manner regarding all matters related to data protection that arise in IVASS.

SECOND: NOTIFY this resolution to the VALENCIAN INSTITUTE OF SOCIAL SERVICES (IVASS).

THIRD: COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of

Article 77.5 of the LOPDGDD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Presidency of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency is not aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension to be concluded.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

43/43

938-101224

Olga Pérez Sanjuán

Deputy Director General of Data Inspection, in accordance with Article 48.2 LOPDGDD, due to the vacancy of the Presidency and Deputy Presidency of the AEPD

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es